

A Knowledge-Graph Audit of Privacy Policy Compliance and Disclosure Obfuscation Across the Technology, Healthcare, and Financial Sectors

Vijayalakshmi Ramasamy^{1*}, Gokila Dorai² and Luke Blevins¹

^{1*}Computer Science, Georgia Southern University, 1100 IT Drive, Statesboro, 30458, GA, USA.

²Department, Organization, Street, City, 10587, State, Country.

*Corresponding author(s). E-mail(s): vramasamy@georgiasouthern.edu; Contributing authors: GDORAI@augusta.edu; iiiauthor@gmail.com;

Abstract

Privacy policies are the primary public instrument through which organizations declare their data-handling practices, yet assessing their compliance with overlapping regulatory regimes remains difficult at scale. We present a Privacy Policy Knowledge Graph (PPKG) framework that represents each policy as a knowledge graph of data, entity, and relationship nodes and applies a taxonomy of 100 violation codes - 95 GDPR-aligned codes and five CCPA-specific extensions - organized across six research questions and mapped to GDPR Articles 5–49, CCPA §1798, and documented enforcement precedents. A weighted composite transparency score σ integrating coverage, density, transparency, and clarity classifies each policy, and a disclosure-obfuscation proxy ω , grounded in the financial-disclosure readability literature, situates every firm in a two-dimensional cross-document compliance space. We apply the framework to 179 S&P 500 companies spanning three Global Industry Classification Standard sectors: Information Technology ($n = 74$), Health Care ($n = 54$), and Financials ($n = 51$). The central finding is clear and consistent across all sectors: no firm attains strategic compliance ($\sigma \geq 0.70$), 90.5% are non-compliant ($\sigma < 0.50$), and mean GDPR coverage is only 36.2%, which is fewer than four of ten mandatory disclosure categories per policy. Cross-sector differences in the composite score are not significant (Kruskal–Wallis $H = 5.37$, $p = 0.068$), and eleven violation codes spanning five of six research questions trigger for every firm, establishing an economy-wide baseline of structural non-compliance. Component decomposition shows the deficit is structural rather than linguistic: transparency (inverse vagueness) averages **0.99**, but coverage (**0.36**), density (**0.16**), and clarity (**0.24**),

the latter driven by near-zero purpose attribution, are critically low. Transparency and obfuscation are significantly negatively correlated ($r = -0.303$, $p < 0.001$), and no firm occupies the “strategic obfuscator” quadrant, supporting a systems rather than strategic account in which disclosure behavior is an integrated organizational characteristic that manifests consistently across regulatory domains.

Keywords: privacy policy analysis, knowledge graphs, GDPR compliance, CCPA, regulatory technology, disclosure obfuscation, cross-sector analysis

1 Introduction

Privacy policies are the principal public instrument through which organizations disclose how they collect, process, share, and retain personal data. Under the General Data Protection Regulation (GDPR) [1] and the California Consumer Privacy Act (CCPA) [2], these documents are not mere formalities, but legally binding declarations against which regulators measure conduct and assess penalties. Enforcement actions of unprecedented scale, such as the €1.2B Meta transfer fine [3], the €746M Amazon penalty for vague recipient disclosure [4], and the €310M LinkedIn behavioral-advertising decision [5], demonstrate that deficiencies in policy disclosure carry material financial and reputational consequences. Yet privacy policies are often long, opaque, and inconsistent, and the manual legal review required to assess their compliance does not scale to the thousands of organizations operating under overlapping regulatory regimes [6, 7].

Computational approaches to privacy policy analysis have advanced considerably, from corpus construction and supervised classification [8, 9] to deep-learning summarization [10] and, more recently, knowledge-graph (KG) representations that capture the entity–data–purpose relationships embedded in policy text [11]. Graph-based methods are particularly well suited to compliance assessment because regulatory obligations are inherently relational: GDPR Article 13(1)(e) concerns *which* recipients receive *which* data for *which* purposes, and contradiction-detection frameworks such as PolicyLint [12] show that inconsistencies surface precisely in the structure of stated data flows. However, existing work has largely focused on individual regulations, narrow policy corpora (often mobile applications), or descriptive extraction, rather than on systematic, multi-regulatory deficiency detection across an economically significant population of organizations. Our prior work [13, 14] established the feasibility of graph-mining and NLP techniques for privacy policy analysis; the present paper extends that foundation into a formal, multi-regulatory compliance framework applied at scale.

This paper introduces a Privacy Policy Knowledge Graph (PPKG) framework that operationalizes regulatory compliance as a graph-analytic problem. Each policy is represented as a knowledge graph (KG) $G = (V, E)$ whose nodes denote data categories and entities, and whose edges denote relationships for collection, processing, and sharing. We define a taxonomy of 100 violation codes (95 GDPR-aligned codes + five CCPA-specific extensions) mapped to GDPR Articles 5–49, CCPA §1798, and associated enforcement (see Table 1), and organize them into six research questions

spanning disclosure adequacy, graph-structural completeness, lawful-basis reasoning, third-party transparency, internal contradiction, and aggregate enforcement risk. Each code is prefixed by its dimension: $\mathcal{V}$ (Violation codes for disclosure requirement), $\mathcal{S}$ (structural code), $\mathcal{C}$ (Compliance (lawful basis) code), $\mathcal{T}$ (third-party code), $\mathcal{X}$ (contradiction code), $\mathcal{R}$ (risk code), and $\mathcal{CC}$ (CCPA extensions code). Beyond per-policy detection, the framework situates each firm in a two-dimensional *cross-document compliance space* defined by a *composite privacy-transparency score* σ and a *disclosure-obfuscation proxy* ω grounded in the financial-disclosure readability literature [15, 16], enabling a unified view of disclosure behavior across regulatory domains. Throughout, “violation” denotes a measurable gap between a policy’s disclosed content and a regulatory requirement, assessed relative to the GDPR’s extraterritorial reach (Article 3) and the CCPA, and indicating disclosure risk rather than an adjudicated breach. Concretely, we investigate:

- **RQ1:** To what extent do policies satisfy GDPR Article 13/14 mandatory disclosure requirements, and which elements are most frequently omitted? (codes $\mathcal{V}01\text{--}\mathcal{V}13$, $\mathcal{CC}01\text{--}\mathcal{CC}02$)
- **RQ2:** Do graph-structural metrics of density, connectivity, and clustering serve as proxies for disclosure completeness? (codes $\mathcal{S}01\text{--}\mathcal{S}14$)
- **RQ3:** How adequately do policies document the lawful basis for processing, including special-category data and CCPA obligations? (codes $\mathcal{C}01\text{--}\mathcal{C}18$, $\mathcal{CC}05$)
- **RQ4:** How transparent are policies regarding third-party recipients, and how specifically are those recipients identified? (codes $\mathcal{T}01\text{--}\mathcal{T}16$, $\mathcal{CC}03\text{--}\mathcal{CC}04$)
- **RQ5:** What internal contradictions arise between stated practices and disclosed data flows? (codes $\mathcal{X}01\text{--}\mathcal{X}18$)
- **RQ6:** How do cross-dimensional findings aggregate into a quantifiable enforcement-risk profile and compliance classification? (codes $\mathcal{R}01\text{--}\mathcal{R}16$)

We apply the framework to 179 S&P 500 companies drawn from three Global Industry Classification Standard (GICS) sectors, namely *Information Technology* ($n = 74$), *Health Care* ($n = 54$), and *Financials* ($n = 51$), selected because these dominant sectors among S&P 500 companies handle distinct categories of sensitive data under partially divergent regulatory expectations. The main empirical finding is clear and consistent: *not one* of the 179 firms attains the strategic-compliance threshold ($\sigma \geq 0.70$), 90.5% are classified non-compliant ($\sigma < 0.50$), and the remaining 9.5% reach only performative compliance. Mean GDPR coverage is just 36.2%, which is fewer than four of the ten mandatory disclosure categories per policy, and eleven violation codes, spanning five of the six research questions, trigger for *every* firm in the corpus, establishing a sector-invariant baseline of structural non-compliance. Cross-sector differences in the composite score are not statistically significant (Kruskal–Wallis $H = 5.37$, $p = 0.068$), indicating that this disclosure deficit is an economy-wide phenomenon rather than a sectoral artifact.

Two results sharpen the interpretation. (i) decomposing the composite score reveals that the deficit is *structural rather than linguistic*: transparency (inverse vagueness) averages 0.99, yet coverage (0.36), density (0.16), and clarity (0.24) are critically low,

meaning that policies use precise language but fail to connect data collection to its purposes, legal bases, retention, and recipients. Purpose attribution, the structural link between collection and stated purpose, is essentially absent across the corpus. (ii) the transparency and obfuscation dimensions are significantly and negatively correlated ($r = -0.303$, $p < 0.001$): firms with more transparent privacy policies also exhibit lower disclosure obfuscation, and notably no firm occupies the “strategic obfuscator” quadrant of transparent privacy paired with high obfuscation. This supports a *systems* rather than *strategic* view of corporate disclosure: Compliance behavior is an organizational trait that consistently manifests across regulatory domains, not just in consumer-facing transparency. The contributions of this work are fourfold:

1. A **multi-regulatory violation taxonomy** of 100 codes spanning GDPR and CCPA obligations, each linked to a specific provision and a severity tier calibrated against documented enforcement precedents.
2. A **graph-analytic detection methodology** that translates these obligations into computable checks over privacy policy KGs, with a transparent composite scoring, tiering, and risk-classification scheme.
3. A **cross-document compliance space** that jointly models privacy transparency (σ) and disclosure obfuscation (ω), providing a unified, empirically testable account of disclosure behavior across regulatory domains.
4. A **large-scale empirical study** of 179 S&P 500 companies, whose central finding is that zero strategically compliant firms and an economy-wide, sector-invariant structural deficit furnish a quantitative baseline for regulators, forensic practitioners, and policy drafters.

The remainder of this paper is organized as follows. Section 2 reviews knowledge-graph representation techniques for privacy compliance and situates the framework within forensic, cybersecurity, and civil-litigation contexts. Section 3 formalizes the PPKG representation, the 100-code taxonomy, the composite and obfuscation scores, and the cross-document space. Section 4 presents the empirical results for each research question, and Section ?? discusses their theoretical and practical implications. Section 5 concludes and outlines directions for future work.

2 Related Work

The automated analysis of privacy policies has progressed through several methodological generations. Early efforts established that policies are systematically difficult for users to comprehend and frequently misaligned with actual practice [6, 7, 17], motivating computational alternatives to manual review. The release of annotated corpora such as OPP-115 [8] enabled supervised classification of policy segments, and subsequent systems scaled these techniques to large application populations: MAPS analyzed roughly one million Android apps for compliance discrepancies [9], while machine-learning approaches assessed policy completeness [18] and audited third-party data-collection disclosures [19]. Deep-learning methods improved comprehension and presentation, with Polisis [10] classifying and summarizing policy content and dedicated models targeting vague or ambiguous language [20]. Despite this progress, classification-based approaches largely treat policies as bags of segments rather than

as structured data-flow descriptions, limiting their ability to reason about relational obligations such as which recipients receive which data for which purposes.

2.1 Knowledge-Graph Representation Techniques

Knowledge-graph representations address this limitation by modeling policies as networks of entities, data categories, and their relationships. We organize the relevant techniques into four families. *Semantic-web and ontology-based* approaches encode privacy concepts in formal vocabularies—most prominently the W3C Data Privacy Vocabulary and legal-reasoning ontologies such as PrOnto—and support integrated multi-regulatory reasoning, but depend on manual ontology engineering and policy-to-ontology mapping. *NLP pipeline architectures* extract graphs directly from policy text: PoliGraph performs cross-sentence relation extraction [11], while related systems apply Sentence-BERT-style semantic normalization [21] to collapse lexical variants onto common nodes. *LLM-augmented construction* methods use large language models for graph extraction and zero-shot classification, trading annotation cost for prompt sensitivity and grounding challenges. Finally, *graph neural networks and embeddings* cast compliance as a learned prediction over graph structure, and *deontic-logic and formal policy languages* (e.g. OWL2- and ODRL-based machine-actionable policies) target real-time, automated compliance checking.

The framework combines an NLP-built KG with an explicit, auditable taxonomy of 100 deterministic deficiency checks across two regulatory regimes, prioritizing interpretability and enforcement traceability, which are crucial for forensic and regulatory uses. Prior graph-based efforts have also targeted regulatory verification directly, automating GDPR and PCI DSS compliance checks [22], verifying contractual compliance against GDPR obligations [23], and enforcing policies in decentralized data-collection systems [24]; our prior conference work [13, 14] explored graph-mining and NLP for user-centric policy analysis. The present work differs in defining a unified, severity-calibrated multi-regulatory taxonomy and applying it comparatively, with an accompanying cross-document obfuscation analysis, across an economically significant population of public companies.

2.2 Forensic and Cybersecurity Perspectives

Beyond compliance assessment, privacy policies serve as digital artifacts directly relevant to cybersecurity and digital forensics. As legally binding commitments regarding data handling, they establish an auditable baseline against which investigators can detect deviations, reconstruct data-flow expectations, and identify unauthorized information sharing during post-incident analysis [19]. Structured graph representations of data flows, sharing relationships, and consent mechanisms can be cross-referenced against network logs, access records, and audit trails, providing forensic analysts with authoritative documentation of what data should exist, where it should reside, and with whom it should be shared [11]. Discrepancies between these policy-derived expectations and forensic findings can reveal shadow systems, undisclosed integrations, or insider misuse, as illustrated by enforcement actions involving employee surveillance and undisclosed data practices [25]. The sector-invariant baseline of structural non-compliance established in this paper is directly useful in this setting: because no S&P 500 firm achieves strategic compliance, an investigator can express a given

firm’s deviation from the corpus mean as a standardized score, distinguishing inherent domain complexity from anomalous opacity.

The relevance of cybersecurity extends from reactive forensics to proactive risk assessment. Organizations that collect biometric, health, or financial data present elevated attack surfaces, and systematically analyzing these data collection patterns supports threat modeling and security control prioritization [26, 27]. This intersection is reinforced by regulations that impose security and privacy obligations: GDPR [1] and HIPAA [28] mandate breach notification, data minimization, and accountability, while statutes such as the Illinois Biometric Information Privacy Act [29] impose heightened requirements on sensitive identifiers. Integrating policy KGs with security information and event management workflows to enable continuous monitoring of data flows against policy-defined baselines remains largely unrealized opportunity.

2.3 Civil Litigation and Regulatory Investigation Perspectives

Privacy policies have also become pivotal evidentiary documents in civil litigation, where they are increasingly treated as express contractual warranties rather than legal boilerplate [6, 30]. Graph-based analysis provides litigation teams with tools to identify material misrepresentations and patterns of systematic non-compliance: when a policy claims that data is not shared with advertisers yet the underlying data-flow graph reveals explicit advertising relationships, this constitutes actionable evidence of the kind underlying numerous enforcement actions [31–33]. By converting deliberately obfuscating language into structured entity–relationship triples, computational methods allow courts to compare what policies actually disclose against what companies claim they disclose [18, 34], while the notice-and-consent model that underpins much of this litigation has itself been extensively critiqued as insufficient [35, 36].

The evidentiary applications span multiple contexts. In securities and shareholder actions, systematic comparison of policy disclosures against operational practice can establish corporate misrepresentation, as exemplified by the \$5 billion Facebook settlement [31] and subsequent enforcement [37]. Product-liability and consumer-protection suits involving connected devices and health applications have relied on policy analysis to demonstrate excessive collection or undisclosed sharing [38–40]. Children’s privacy enforcement under COPPA [41] has produced repeated penalties [42–44], and biometric-privacy litigation under BIPA has generated substantial settlements [45, 46]. Regulators increasingly employ automated screening to triage thousands of policies and flag outliers whose disclosed practices diverge from sectoral norms [9, 12], while courts have grown more receptive to privacy-based causes of action [47, 48]. This convergence of computational analysis and regulatory enforcement underscores the value of scalable, multi-regulatory frameworks of the kind developed here.

3 Methodology

This section formalizes the Privacy Policy Knowledge Graph (PPKG) framework and its application to the S&P 500 corpus. We define the graph representation, the process for converting policy text into graphs, the extracted feature vector, and the taxonomy of 100 violation codes. We then present the composite transparency score and compliance tiers, the obfuscation proxy and cross-document compliance space, the

dataset, the statistical methods, the implementation, and the scope and limitations. The complete pipeline appears in Figure 1.

3.1 Privacy Policy Knowledge Graph Representation

We model each privacy policy as a directed KG, $G = (V, E)$. The node set $V = V_D \cup V_A \cup V_P$ partitions into *data nodes* V_D (categories of collected information, e.g. `email address`, `health data`), *actor nodes* V_A (the first party and the third-party entities that collect, process, or receive data), and *purpose nodes* V_P (stated reasons for processing). The edge set $E = E_C \cup E_S \cup E_H \cup E_P$ is typed by relationship: collection edges E_C (COLLECT) link actors to the data they obtain; sharing edges E_S (SHARE) link data to third-party recipients; subsumption edges E_H (SUBSUM) encode hierarchical or processor relationships; and purpose edges E_P link collection or sharing to a stated purpose. Each node and edge carries a textual label drawn from the source policy, which supports the linguistic features defined below. The degree to which purpose edges connect collection to stated purposes, *purpose attribution*, is a central transparency signal throughout the analysis.

The fidelity of all downstream metrics depends on graph construction, which is summarized here; full details of the extraction pipeline appear in our prior work [13, 14]. We construct each policy knowledge graph by adapting PoliGrapher, the extraction component of the PoliGraph framework [11], to parse policy text into typed data–actor–purpose relationships. Each company’s published privacy policy is segmented into sentences, and an NLP pipeline identifies candidate data types, actors, and purposes, together with the collection, sharing, and processing relations among them. Entity mentions are normalized using contextual sentence embeddings [21] so that lexical variants (e.g. “personal information” and “personal data”) map to a common node, and typed edges are instantiated where a sentence asserts a corresponding relationship. The resulting graphs are serialized as GraphML files, one per company, and organized by sector.

Given a collection $\mathcal{G} = \{G_1, \dots, G_n\}$, the framework proceeds through five phases - *ingestion*, *feature extraction*, *multi-dimensional deficiency detection*, *composite and obfuscation scoring*, and *cross-document classification and reporting*, summarized in Figure 1. Because construction is automated, the features and codes below inherit the precision of the extraction stage; we quantify the implications in Section 4.10.

3.2 Feature Extraction and Violation Taxonomy

From each graph G , we extract a feature vector f_G capturing structural, semantic, and disclosure properties.

Structural metrics. We compute node count $n = |V|$, edge count $m = |E|$, density $\delta = 2m/(n(n-1))$, and on the undirected projection, number of connected components, average clustering, degree-centrality statistics, and collection-to-edge ratio, which serve as proxies for disclosure completeness and coherence [11, 12].

GDPR category coverage. We assess 10 mandatory Article 13/14 disclosure element presence: controller identity, DPO contact, processing purposes, lawful basis, data categories, recipients, retention periods, data subject rights, international transfers, and automated decision-making via keyword matching over node, edge labels:

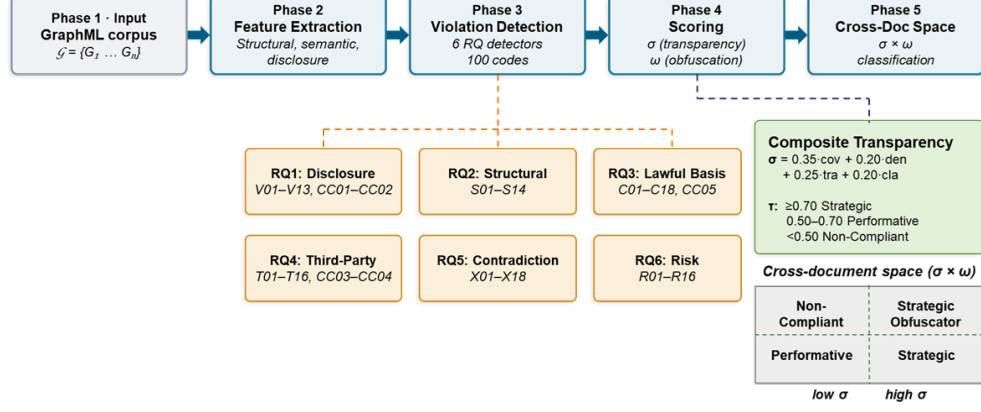


Fig. 1 PPKG compliance assessment pipeline. Each privacy policy KG is reduced to a feature vector (Phase 2), evaluated by six RQ detectors implementing 100 violation codes (95 GDPR-aligned + five CCPA extensions) mapped to GDPR Articles 5–49 + CCPA §1798 (Phase 3), scored on a composite transparency index σ and an obfuscation proxy ω (Phase 4), and positioned in the cross-document compliance space (Phase 5).

$$s_{\text{cov}} = \frac{|\{c \in \mathcal{C} : c \text{ detected in } G\}|}{|\mathcal{C}|}, \quad |\mathcal{C}| = 10. \quad (1)$$

CCPA features. Five CCPA-specific indicators, “Do Not Sell” mechanism (§1798.135), personal information categories collected, business/commercial purpose, sale disclosure, and third-party categories (§1798.115), and the mean is CCPA coverage s_{ccpa} .

Third-party specificity. Actor nodes excluding the first party form the third-party set, each classified as *specific* (a named organization) or *generic* (a vague category such as “service providers”). The specificity ratio quantifies recipient transparency:

$$s_{\text{tra}} = \frac{|\text{specific third parties}|}{|\text{specific}| + |\text{generic}|}. \quad (2)$$

Purpose attribution. Fraction of *collection* and *sharing* edges connected to a stated purpose node, capturing whether disclosed data flows are tied to a declared reason for processing:

$$p_{\text{attr}} = \frac{|\{e \in E_C \cup E_S : e \text{ linked to } V_P\}|}{|E_C \cup E_S|}. \quad (3)$$

Linguistic clarity. The vagueness ratio is the frequency of modal and hedging terms (e.g. “may,” “might,” “could”) relative to total terms [6, 20]; clarity is its complement, $s_{\text{cla}} = 1 - r_{\text{vague}}$.

Special-category indicators. We flag the presence and count of Article 9 special-category data (health, biometric, genetic) among data nodes, feeding the lawful-basis detectors of RQ3.

The core of the framework is a taxonomy of 100 violation codes: 95 GDPR-aligned codes organized into six research-question detectors, plus five CCPA-specific extensions (CC01–CC05) integrated into the relevant detectors. Table 1 enumerates all 100 codes with their article mappings and severities.

Table 1: Complete PPKG violation taxonomy: all 100 codes with article mapping and severity (S) (C = Critical, H = High, M = Medium), two codes per row.

Code	Description	Article	S	Code	Description	Article	S
RQ1 — Disclosure Requirements (V01–V13, CC01–CC02)							
V01	Controller identity missing	13(1)(a)	H	V02	DPO contact missing	13(1)(b)	M
V03	Processing purposes missing	13(1)(c)	H	V04	Lawful basis missing	13(1)(c)	C
V05	Recipients Vague/missing	13(1)(e)	H	V06	Int'l transfers missing	13(1)(f)	C
V07	Retention period missing	13(2)(a)	H	V08	Data subj. rights missing	13(2)(b–d)	H
V09	Automated decisions missing	13(2)(f)	M	V10	Data categories missing	5(1)(e)	M
V11	High vagueness (>15%)	12(1)	M	V12	Low purpose attr. (<65%)	5(1)(b)	H
V13	Special-cat. safeguards missing	9	C	CC01	Notice/categories absent	§1798.100	H
CC02	Business purpose absent	§1798.100(d)	M				
RQ2 — Structural Analysis (S01–S14)							
S01	Critically sparse (<0.05)	5(1)(a)	C	S02	Below-thresh.(0.05–0.08)	5(1)(a)	H
S03	Low clustering (<0.1)	5(1)(a)	H	S04	High fragmentation (>5)	5(1)(a)	H
S05	Low collection ratio (<0.3)	5(1)(a)	H	S06	Imbalanced edge types	5(1)(a)	M
S07	Excessive hub centrality	5(1)(a)	H	S08	Low centrality variance	5(1)(a)	M
S09	Edge-type diversity <3	5(1)(a)	M	S10	Component fragmentation	5(1)(a)	M
S11	Insufficient nodes (<10)	5(1)(a)	M	S12	Excess nodes, few edges	5(1)(a)	M
S13	Low LCC coverage (<0.5)	5(1)(a)	H	S14	Node–edge imbalance	5(1)(a)	H
RQ3 — Compliance Reasoning (C01–C18, CC05)							
C01	No lawful basis	6(1)	C	C02	Inadequate consent	6(1)(a)	H
C03	Missing contract necessity	6(1)(b)	H	C04	Undoc. legit. interest	6(1)(f)	H
C05	Special cat. no consent	9(1)	C	C06	Missing Art.9(2) excep.	9(2)	C
C07	Consent not demonstrable	7(1)	H	C08	No withdrawal mechanism	7(3)	H
C09	Fairness violation	5(1)(a)	H	C10	Purpose limit. violation	5(1)(b)	H
C11	Data minimization violation	5(1)(c)	H	C12	No privacy-by-design	25(1)	M
C13	No privacy-by-default	25(2)	M	C14	Transfer w/o safeguards	44–49	C
C15	Missing right-to-know	§1798.100	H	C16	Missing opt-out of sale	§1798.120	C
C17	Missing access procedure	15	H	C18	Missing erasure procedure	17	H
CC05	“Do Not Sell” link absent	§1798.135	C				
RQ4 — Third-Party Network (T01–T16, CC03–CC04)							
T01	No third party identified	13(1)(e)	C	T02	Low TP specificity (.3–.5)	13(1)(e)	H
T03	Exclusively generic cats.	13(1)(e)	H	T04	Critical specificity (<.3)	13(1)(e)	C
T05	Missing data-cat. per TP	5(1)(b)	H	T06	Incomp. sharing purpose	5(1)(b)	H
T07	Undisclosed ad partners	13(1)(e)	H	T08	Cross-border undisclosed	44	C
T09	Joint-controller hidden	26	C	T10	Missing TP categories	§1798.115	H
T11	Undisclosed sale recipients	§1798.120	C	T12	TP purpose mismatch	5(1)(b)	H
T13	High count, low detail	13(1)(e)	H	T14	Data-broker hidden	§1798.120	C
T15	Sub-processor chain hidden	28(3)	M	T16	Transfer jurisdict. unclear	44	C
CC03	TP disclosure cats. absent	§1798.115	H	CC04	Sale disclosure missing	§1798.115	H
RQ5 — Contradiction Detection (X01–X18)							
X01	High vagueness (>15%)	5(1)(a)	H	X02	Critical vagueness(>25%)	5(1)(a)	C
X03	Excessive modal language	12(1)	M	X04	Collection–denial contra.	5(1)(a)	C
X05	Sharing–denial contra.	5(1)(a)	C	X06	Purpose inconsistency	5(1)(b)	H
X07	Low purpose attrib. (<65%)	5(1)(a)	H	X08	Crit. attrib. gap(<40%)	5(1)(a)	C
X09	TP count mismatch	13(1)(e)	H	X10	Minimization contra.	5(1)(c)	H
X11	Consent contradiction	7(1)	C	X12	Deletion–retention contra.	17	H
X13	Security–practice gap	5(1)(a)	M	X14	Sale contra. (ads, no disc.)	§1798.100	C
X15	Orphan data nodes	5(1)(a)	M	X16	Circular/fragmented defs.	5(1)(a)	M
X17	Ambiguous entity IDs	12(1)	H	X18	Tracking contradiction	5(1)(a)	C
RQ6 — Risk Quantification (R01–R16)							
R01	Critical risk score (<0.4)	5(1)(a)	C	R02	High risk score (0.4–0.5)	5(1)(a)	H
R03	Coverage deficiency (<50%)	12(1)	C	R04	Low coverage (50–60%)	12(1)	H
R05	Critical density (<0.05)	5(1)(a)	C	R06	High density risk(.05–.08)	5(1)(a)	H
R07	Low transparency (<0.4)	5(1)(a)	H	R08	Low clarity (<0.5)	12(1)	H
R09	Multi-flag risk (>3)	5(1)(a)	C	R10	Violation load >20	5(1)(a)	C
R11	Violation load 15–20	5(1)(a)	H	R12	≥5 critical codes	5(1)(a)	C
R13	≥10 high codes	5(1)(a)	H	R14	Node–edge imbalance	5(1)(a)	H
R15	Systemic accountability fail	5(2)	C	R16	Cross-RQ accumulation	5(1)(a)	C

The six detectors operationalize complementary dimensions. Each code maps to a specific provision across GDPR Articles 5–49 and CCPA §1798 and is assigned a severity—CRITICAL, HIGH, or MEDIUM. Severity tiers are *calibrated against*, rather than statistically validated on, documented enforcement actions: CRITICAL codes correspond to provisions underlying the largest penalties (e.g. the €1.2B Meta transfer

fine [3] and the €746M Amazon recipient-disclosure penalty [4]), HIGH codes to core transparency failures, and MEDIUM codes to *comprehension* and *structural* issues. RQ1 (V01–V13, CC01–CC02) checks mandatory Article 13/14 elements and core CCPA disclosures. RQ2 (S01–S14) treats graph topology as a candidate proxy for completeness, a premise we test rather than assume. RQ3 (C01–C18, CC05) verifies lawful basis under Articles 6, 7, and 9 and the CCPA opt-out obligation. RQ4 (T01–T16, CC03–CC04) assesses recipient transparency under Article 13(1)(e), Article 28, and the CCPA. RQ5 (X01–X18) detects contradictions between stated practices and observed data flows, extending PolicyLint [12]. RQ6 (R01–R16) aggregates the preceding findings into enforcement-risk indicators, including a multi-flag code (R09) for firms exhibiting deficiencies across multiple dimensions. Table 2 summarizes the distribution. Detection is deterministic: each code fires when its threshold test over f_G is met—for example, S01 when $\delta < 0.03$, T04 when third parties are exclusively generic, and X08 when $p_{\text{attr}} < 0.5$.

Table 2 Violation code distribution by RQ and severity. Five CCPA extension codes (CC01–CC05) are distributed across RQ1 (CC01–CC02), RQ3 (CC05), and RQ4 (CC03–CC04).

RQ	Dimension & Code-family Prefixes	Codes	CRIT	HIGH	MED
RQ1	Disclosure (V, CC)	15	3	7	5
RQ2	Structural (S)	14	1	7	6
RQ3	Lawful basis (C, CC)	19	6	11	2
RQ4	Third-party (T, CC)	18	7	10	1
RQ5	Contradiction (X)	18	7	7	4
RQ6	Risk (R)	16	7	7	2
Total		100	31	49	20

3.3 Composite Transparency Score and Compliance Tiers

The four normalized components are combined into a composite transparency score with weights reflecting regulatory importance:

$$\sigma = 0.35 s_{\text{cov}} + 0.20 s_{\text{den}} + 0.25 s_{\text{tra}} + 0.20 s_{\text{cla}}, \quad (4)$$

where the density component is normalized against an adequacy reference, $s_{\text{den}} = \min(\delta/0.15, 1)$, and s_{cov} , s_{tra} , s_{cla} follow Equations (1)–(2) and the clarity definition. The score $\sigma \in [0, 1]$ is mapped to a compliance tier:

$$\tau(\sigma) = \begin{cases} \text{STRATEGIC}, & \sigma \geq 0.70, \\ \text{PERFORMATIVE}, & 0.50 \leq \sigma < 0.70, \\ \text{NON-COMPLIANT}, & \sigma < 0.50. \end{cases} \quad (5)$$

The STRATEGIC tier denotes substantive transparency; PERFORMATIVE denotes formal disclosure without substantive structure; and NON-COMPLIANT denotes failure to meet either. Because s_{tra} , s_{cov} , s_{cla} , and s_{den} are constituents of σ , correlations between a single component and σ are partly definitional; we interpret such associations only as descriptions of variance structure (Section ??).

3.4 Obfuscation Proxy and Cross-Document Compliance Space

To situate privacy disclosure within the broader regulatory-reporting behavior of each firm, we compute a disclosure-obfuscation proxy $\omega \in [0, 1]$ from four equally weighted graph-derived components, motivated by the financial-disclosure readability literature [15, 16, 49]: a *size factor* (graph magnitude relative to disclosed substance), a *density inverse* ($1 - s_{\text{den}}$, rewarding relational sparsity), a *vagueness* term, and an *attribution gap* ($1 - p_{\text{attr}}$):

$$\omega = \frac{1}{4}(\omega_{\text{size}} + \omega_{\text{den}} + \omega_{\text{vague}} + \omega_{\text{attr}}). \quad (6)$$

Higher ω indicates greater structural obfuscation. The proxy is derived from graph metrics rather than from SEC filings directly; we treat it as a measurable surrogate for cross-document disclosure behavior and discuss this assumption in Section 4.10.

Each firm is then positioned in a two-dimensional *cross-document compliance space* with transparency σ on one axis and obfuscation ω on the other. The space is partitioned into four quadrants: STRATEGICALLY COMPLIANT (high σ , low ω), PERFORMATIVELY COMPLIANT (moderate σ , low ω), NON-COMPLIANT (low σ , high ω), and STRATEGIC OBFUSCATOR (high σ , high ω). The last quadrant operationalizes the hypothesis that a firm might present a transparent privacy policy while obscuring disclosure elsewhere; its occupancy is an empirical question addressed in Section 4.

3.5 Dataset

We assembled privacy policy KGs for 179 S&P 500 companies spanning three GICS sectors: Information Technology ($n = 74$), Health Care ($n = 54$), and Financials ($n = 51$). These sectors were selected because they process distinct classes of sensitive data—consumer behavioral data, protected health information, and financial records—under partially divergent regulatory regimes, enabling a controlled cross-sector comparison. To assess cross-sector differences, we apply the Kruskal-Wallis H test for an overall comparison across the three sectors, followed by pairwise Mann-Whitney U tests (also called the Wilcoxon rank-sum test), with Cohen’s d effect sizes, using non-parametric methods because the score and violation distributions are non-normal. The relationship between transparency and obfuscation is quantified with Pearson correlation. To characterize feature importance while avoiding the definitional circularity noted in Section 3.3, we distinguish component- σ correlations (descriptive of variance structure only) from correlations against total violation load, an outcome independent of the scoring weights. We report significance at $p < 0.05$ (*) and $p < 0.01$ (**), and treat $0.05 \leq p < 0.10$ as marginal. The framework is implemented in Python using NetworkX [50] for graph analysis, with pandas for tabular processing and SciPy for statistical testing. Feature extraction runs in $O(|V| + |E|)$ per graph and violation mapping in $O(100)$ constant checks, giving an overall complexity of $O(n(|V| + |E|))$ for n companies.

4 Results

This section presents the experimental results of the PPKG framework applied to 179 privacy policy KGs from S&P 500 companies across three GICS sectors: Information Technology ($n = 74$), Health Care ($n = 54$), and Financials ($n = 51$). The

analysis evaluates 100 violation codes across six research questions, computes composite transparency scores σ and obfuscation proxy scores ω , and maps firms into a cross-document compliance space jointly informed by GDPR, CCPA, and SEC disclosure requirements. Consistent with Section 1, “violation” denotes a measurable gap between a policy’s disclosed content and a regulatory requirement, assessed relative to the GDPR’s extraterritorial scope (Article 3) and the CCPA rather than as an adjudicated breach.

4.1 Corpus Overview and Descriptive Statistics

The corpus comprises 179 privacy policy KGs encoded as GraphML files, representing the unique privacy policies available from the sampled firms across the three sectors. Figure 2 provides a consolidated dashboard and Table 3 reports descriptive statistics for the key compliance metrics.

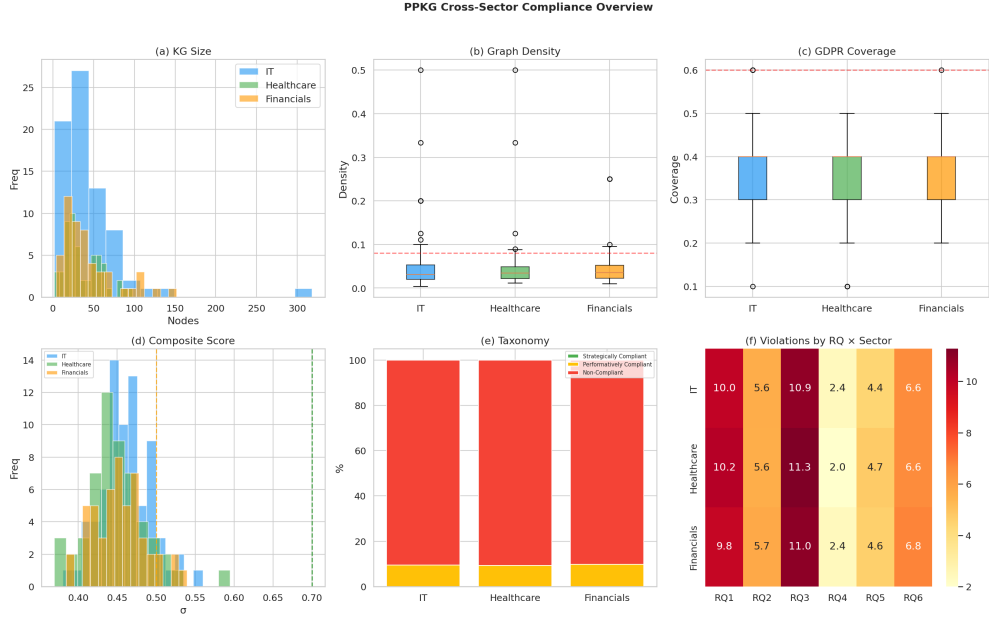


Fig. 2 Overview of the 179-company corpus: distributions of composite scores, obfuscation proxies, compliance classes, and component metrics by sector.

Table 3 Descriptive statistics of compliance metrics by sector (mean; SD in parentheses).

Metric	IT	Health Care	Financials
Composite (σ)	0.462 (0.032)	0.449 (0.039)	0.454 (0.034)
Obfuscation (ω)	0.663 (0.088)	0.662 (0.081)	0.666 (0.076)
GDPR coverage	0.370 (0.111)	0.346 (0.095)	0.373 (0.094)
CCPA coverage	0.027 (0.076)	0.022 (0.063)	0.051 (0.112)
Total violations	40.0 (3.89)	40.5 (3.05)	40.4 (3.92)
Weighted violations	90.5 (10.2)	91.6 (7.73)	91.6 (10.5)

The mean composite transparency score across the corpus is $\sigma = 0.455$ (SD = 0.035), falling well below the 0.70 strategic-compliance threshold and below the 0.50 performative threshold. IT firms exhibit the highest mean ($\mu = 0.462$), marginally exceeding Health Care ($\mu = 0.449$) and Financials ($\mu = 0.454$). A Kruskal–Wallis test reveals no statistically significant cross-sector difference for composite scores ($H = 5.37$, $p = 0.068$), the obfuscation proxy ($H = 0.22$, $p = 0.896$), or GDPR coverage ($H = 2.33$, $p = 0.311$). The sole significant pairwise contrast is the Mann–Whitney comparison between IT and Health Care on composite scores ($U = 2472$, $p = 0.022$, $d = 0.357$), indicating marginally higher transparency among IT firms, consistent with the sector’s greater exposure to data-protection enforcement. The near-uniformity of these metrics is itself the headline result: the disclosure deficit documented below is an economy-wide phenomenon rather than a sectoral artifact.

The mean obfuscation proxy is $\omega = 0.664$ (SD = 0.082), substantially exceeding the 0.50 high-obfuscation threshold. This uniformly elevated value reflects the dominance of the attribution-gap component: purpose attribution is essentially zero across the corpus, meaning that data-collection edges in the KGs are overwhelmingly disconnected from purpose-specification edges (Figure 3). The density-inverse component also contributes substantially ($\mu = 0.83$), indicating that the graphs are structurally sparse relative to their node counts.

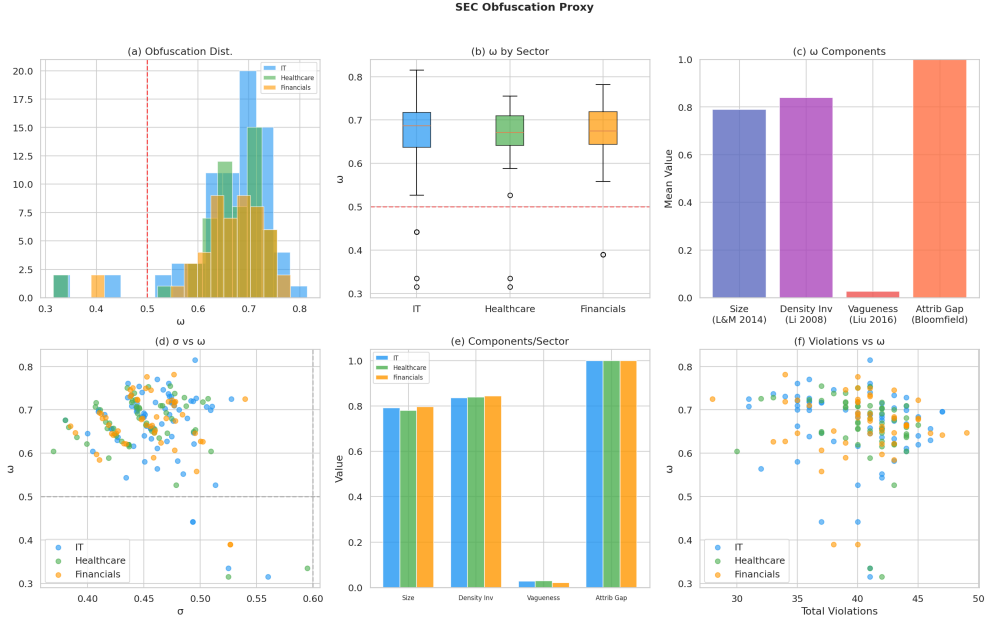


Fig. 3 SEC-style obfuscation proxy ω and its components. The attribution gap dominates, reflecting the near-universal disconnection of collection from stated purpose.

4.2 RQ1: Disclosure Requirements

The disclosure analysis reveals pervasive gaps in GDPR Article 13/14 mandatory requirements (Figure 4). Mean GDPR coverage is only 36.2% across all firms—on

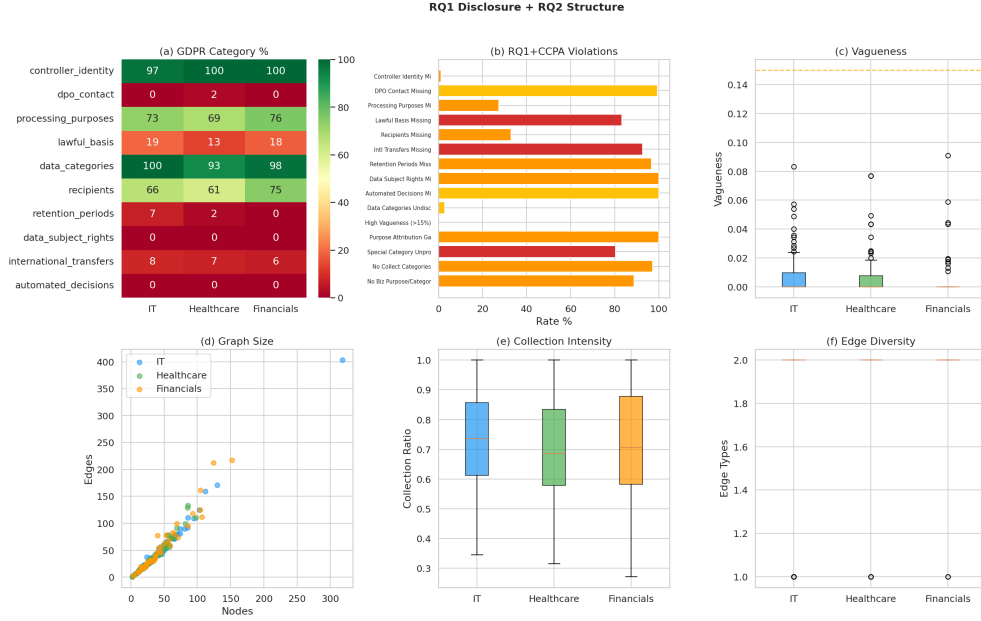


Fig. 4 RQ1 disclosure-element coverage and RQ2 structural metrics by sector.

average, fewer than four of the ten required disclosure categories are present per KG. Controller identity is present in 98.9% of policies, whereas DPO contact information (Art. 13(1)(b)) is absent in 99.4% of firms, the single most frequent disclosure gap. Automated-decision-making disclosures (Art. 13(2)(f), V09), data subject rights specifications (V08), and purpose-attribution links (V12) are each absent in 100% of firms. Eleven violation codes trigger at 100% across all 179 firms (Table 4).

Table 4 Universal violations (100% trigger rate across all 179 firms).

Code	Article	Category	Severity
V08	Art. 13(2)(b–d)	Data subject rights missing	HIGH
V09	Art. 13(2)(f)	Automated decisions missing	MEDIUM
V12	Art. 5(1)(b)	Purpose attribution gap	HIGH
S09	Art. 5(1)(a)	Monotone edge types (< 3)	MEDIUM
C08	Art. 7(3)	Withdrawal mechanism missing	HIGH
C09	Art. 5(1)(b)	Purpose limitation failure	HIGH
C16	CCPA §1798.120	Opt-out right missing	CRITICAL
X07	Art. 5(1)(a)	Purpose attribution gap (> 30%)	HIGH
X08	Art. 5(1)(a)	Critical attribution gap (> 50%)	CRITICAL
R09	Art. 5(1)(a)	Multi-flag (≥ 3 RQ flags)	CRITICAL
R11	Art. 5(1)(a)	Collection without purpose	HIGH

These universal violations span five of the six research questions: V08 (data subject rights), V09 (automated decisions), and V12 (purpose attribution) from RQ1;

S09 (monotone edge types) from RQ2; C08 (withdrawal mechanism), C09 (purpose limitation), and C16 (CCPA opt-out) from RQ3; X07 and X08 (purpose-attribution gaps) from RQ5; and R09 (multi-flag) and R11 (collection without purpose) from RQ6. They account for 11 of the roughly 40 violations per company, establishing a baseline of structural non-compliance that is invariant across sectors and firms. Lawful-basis disclosure (Art. 6, V04) is absent in 83.2% of firms, with Health Care showing the highest deficit (87.0%), followed by Financials (82.4%) and IT (81.1%). International-transfer disclosures (Art. 13(1)(f), V06) are missing in 92.7% of firms, and retention-period specification (V07) in 96.6%—reaching 100% non-disclosure in Financials. These findings extend Rahat et al. [51], who reported 68% non-compliance on at least one GDPR requirement across 9,761 websites, by showing that even among the largest publicly traded firms, the deficit is more severe when assessed through structured knowledge-graph analysis than through surface-level text classification.

4.3 RQ2: Structural Analysis

Structural analysis reveals uniformly sparse topologies across all three sectors (Figure 4, panels d–f). Graph density is critically low: 43.0% of firms fall below the 0.03 critical threshold (S01) and a further 45.3% in the 0.03–0.08 range (S02), so 88.3% of policies have densities below the transparency threshold. The collection-to-edge ratio exceeds 0.6 in 73.7% of firms (S05) and 0.8 in 34.6% (S06), indicating that most edges encode data collection rather than purpose specification, sharing, or hierarchy. Clustering coefficients fall below 0.1 in 85.5% of firms (S13), and 45.3% exhibit zero clustering (S14)—a complete absence of triadic closure. Hub dominance (S08, max degree centrality > 0.5) is present in 53.1% of firms, where a single node—typically the controller—concentrates relationships while peripheral data categories and third parties remain poorly connected. Edge-type monotony (S09) is universal: all 179 firms use fewer than three relationship types, and 7.8% use only one (S10). Collectively, these results indicate that S&P 500 privacy policy KGs are structurally inadequate for representing the relational complexity required by Article 5(1)(a) transparency principle. We note, however, that the impoverished edge vocabulary partly reflects the construction methodology itself (Section 4.10); the structural metrics should therefore be read as joint properties of policy and extraction, an interpretation reinforced by the absence of any significant cross-sector density difference.

4.4 RQ3: Compliance Reasoning

Compliance reasoning produces the highest mean violation count of any research question—13.6 violations per firm from 19 codes (Figure 5). The dominant driver is the absence of a lawful basis (C01, 83.2%), which cascades into dependent violations: C04 (legitimate interest unspecified with > 5 collection edges, 78.8%), C07 (consent not demonstrable combined with missing lawful basis, 83.2%), and C06 (special-category basis missing, 78.8%). The lawful-basis deficit is especially consequential given the enforcement context: the Meta €1.2B fine [3] was predicated on Article 6 failures, establishing the absence of a valid legal ground as a critical-severity exposure.

CCPA-specific analysis reveals severe gaps (Figure 6). CC05 (no “Do Not Sell” link detected) triggers in 99.4% of firms; only 1.4% of IT firms and no Health Care or Financial firms show such indicators in their graph representations. This is consistent

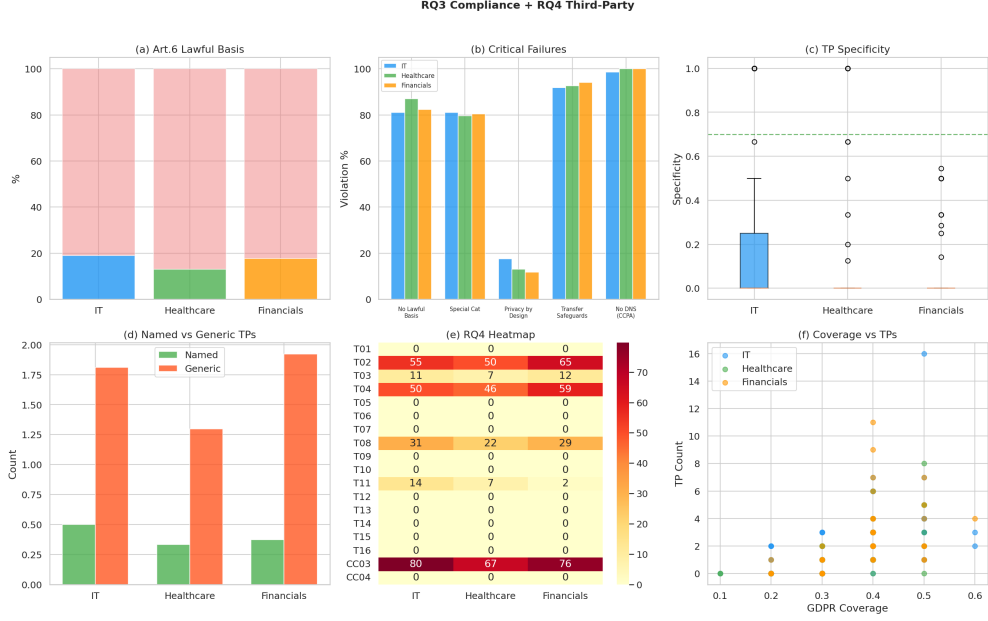


Fig. 5 RQ3 lawful-basis and RQ4 third-party findings by sector.

with the enforcement posture of *In re Sephora* [52], here a \$1.2M settlement followed a failure to provide a “Do Not Sell” link and process opt-out requests. Storage limitation (C11) is absent in 96.6% of firms and transfer safeguards (C14) in 92.7%, indicating that Article 5 data-protection principles and the Article 44–49 transfer requirements are systematically unaddressed in the corpus.

4.5 RQ4: Third-Party Network Analysis

Third-party analysis yields the lowest per-company violation count of any research question ($\mu = 2.3$ from 18 codes; Figure 5, panels c–e), reflecting the sparsity of third-party relationships in the graphs rather than genuine compliance. Low TP specificity (T02, 56.4%) and all-generic TP identification (T04, 51.4%) dominate: when third-party entities appear, they are overwhelmingly described by generic categories (“service provider,” “third party”) rather than named entities. This contravenes the Article 13(1)(e) recipient-identification requirement and aligns with the rationale of the Amazon €746M fine [4], where insufficient third-party specificity was a material finding. The CCPA extension shows that 74.9% of firms with third-party references lack disclosure categories (CC03), and cross-border transfer information (T08) is absent in 27.9% of firms referencing more than two third parties. Financials shows the highest rate of all-generic identification (58.8%), while IT shows the highest named-entity rate, consistent with technology firms’ familiarity with specific infrastructure partners.

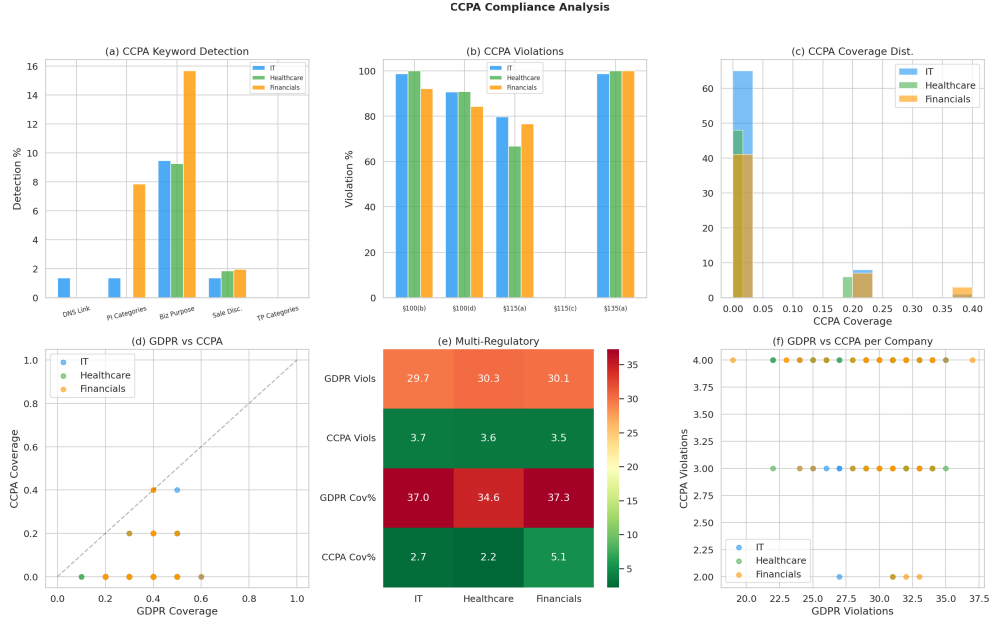


Fig. 6 CCPA-specific feature detection (CC01–CC05) and CCPA-vs-GDPR comparative coverage by sector. Panels (a)–(c) report CCPA keyword detection, violations, and coverage distribution; panels (d)–(f) compare CCPA against GDPR coverage and violation load. CCPA coverage is near-zero across the corpus.

4.6 RQ5: Contradiction Detection

Contradiction analysis identifies 4.6 violations per firm across 18 codes (Figure 7). Purpose-attribution gaps (X07, X08; both 100%) are universal, confirming the systematic disconnection of collection from purpose. Retention contradictions (X13, 91.6%) are pervasive: firms collect data without specifying retention periods, creating an implicit conflict with the Article 5(1)(e) storage-limitation principle. Children’s-data contradictions (X16) trigger in 68.7% of firms—cases with more than ten data nodes but no lawful basis, concerning for entities subject to COPPA or the GDPR’s Article 8 protections for minors—and tracking contradictions (X18) in 88.3%, where extensive collection (> 10 edges) coexists with absent data-subject-rights mechanisms.

Notably, vagueness-related contradictions (X01–X03) and orphan-node violations (X09, X10) trigger at 0%. We interpret this cautiously: rather than indicating genuinely vagueness-free or fully connected policies, it reflects that the graph construction process abstracts away surface-level linguistic features and prunes isolated nodes, so these particular codes have limited discriminative power in the graph representation (Section 4.10).

4.7 RQ6: Risk Quantification and Compliance Taxonomy

The composite scoring yields the central classification result: of 179 firms, 162 (90.5%) are NON-COMPLIANT ($\sigma < 0.50$) and 17 (9.5%) are PERFORMATIVELY COMPLIANT

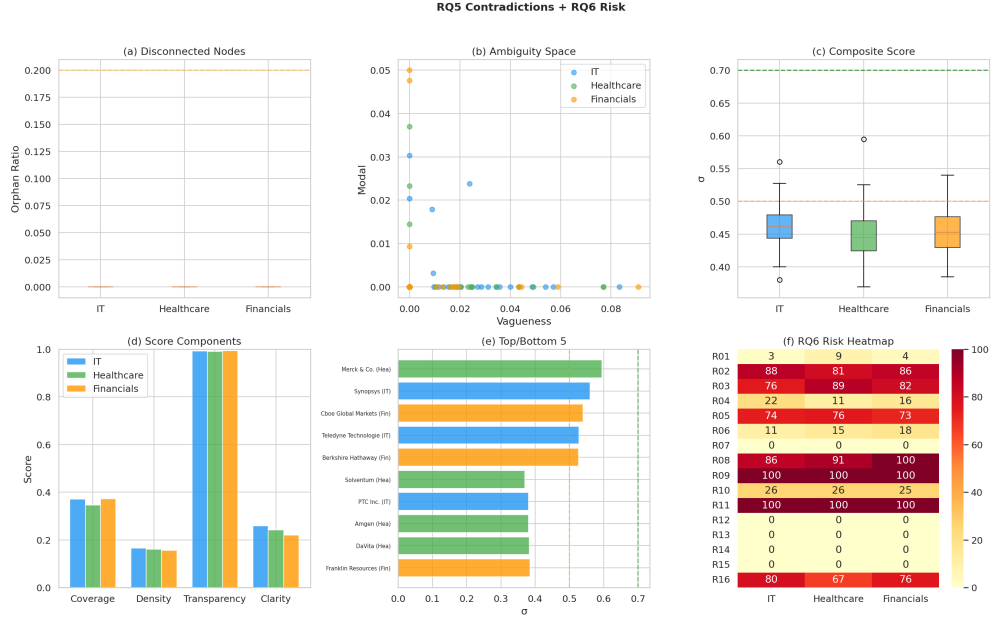


Fig. 7 RQ5 contradiction and RQ6 risk-quantification findings by sector.

($0.50 \leq \sigma < 0.70$); *no* firm reaches the STRATEGIC threshold ($\sigma \geq 0.70$). The distribution is near-identical across sectors (Table 5): IT 90.5%, Health Care 90.7%, and Financials 90.2% non-compliant. The absence of any strategically compliant firm in 179 S&P 500 companies is the most consequential finding of this study, indicating that current privacy policy knowledge-graph representations fail to capture the disclosure specificity and structural interconnectedness required for genuine GDPR transparency.

Table 5 Compliance taxonomy classification by sector; counts (percentages).

Classification	IT	Health Care	Financials
STRATEGIC ($\sigma \geq 0.70$)	0 (0.0%)	0 (0.0%)	0 (0.0%)
PERFORMATIVE (0.50–0.69)	7 (9.5%)	5 (9.3%)	5 (9.8%)
NON-COMPLIANT (< 0.50)	67 (90.5%)	49 (90.7%)	46 (90.2%)

The four component scores reveal the drivers (Figure 7 panels c–d). Transparency (inverse vagueness) is highest ($\mu = 0.99$), while coverage (0.36), density (0.16), and clarity (0.24, driven by near-zero purpose attribution and low third-party specificity) are critically low. The decomposition shows that the compliance deficit is *fundamentally structural* (density, clarity) rather than linguistic (transparency)—a finding with direct implications for enforcement priorities and drafting practice. Among the 17 performatively compliant firms, the highest scores are Merck & Co. ($\sigma = 0.595$, Health Care), Synopsys (0.560, IT), and Cboe Global Markets (0.540, Financials), typically combining higher GDPR coverage (0.20–0.60) with lower obfuscation ($\omega = 0.31$ –0.73). Notably, Berkshire Hathaway and Wells Fargo (Financials, $\sigma = 0.527$) reach performative status with only 20% coverage but low obfuscation

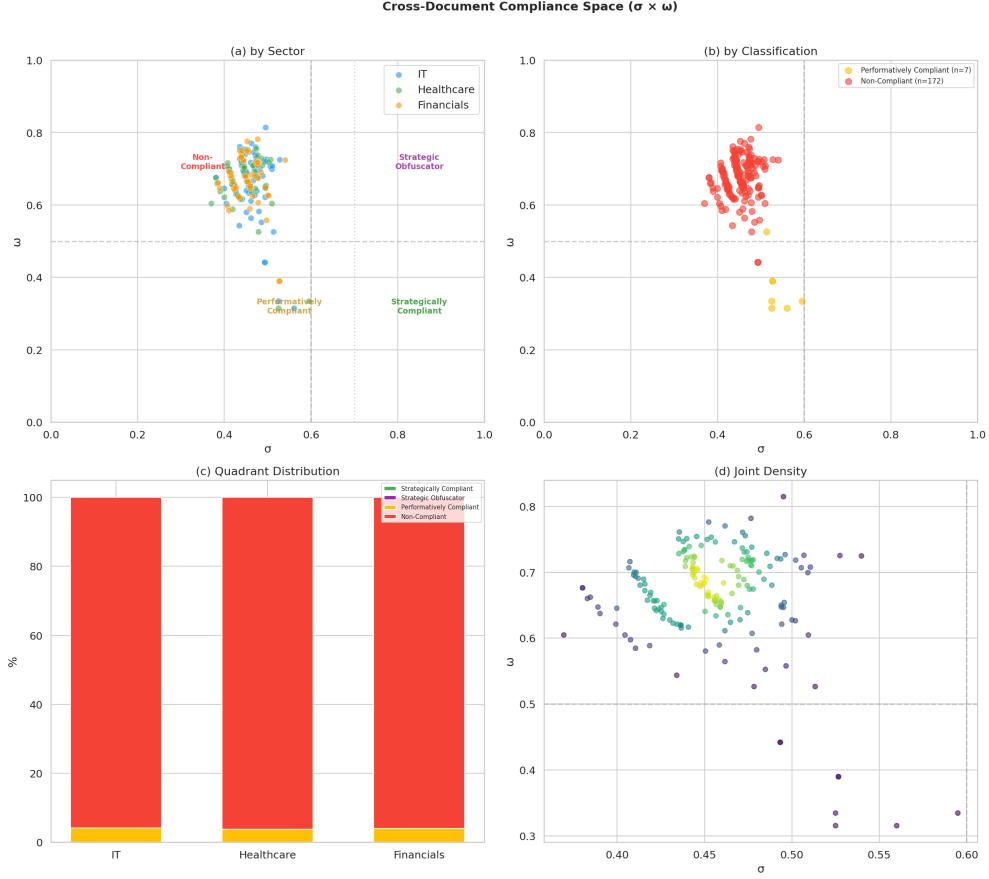


Fig. 8 Cross-document compliance space. Firms are positioned by transparency σ and obfuscation ω ; the strategic and strategic-obfuscator quadrants are empty.

($\omega = 0.390$), suggesting that structural simplicity in the representation—rather than disclosure completeness—drives their classification.

4.8 Cross-Document Compliance Space

The cross-document compliance space (Figure 8) maps all 179 firms by privacy-policy transparency (σ) and disclosure obfuscation (ω). The Pearson correlation between σ and ω is $r = -0.303$ ($p < 0.001$), confirming the predicted negative relationship: firms with higher privacy transparency tend to exhibit lower obfuscation. Under the four-quadrant classification, 172 firms (96.1%) fall in the non-compliant quadrant ($\sigma < 0.60$, $\omega \geq 0.50$) and 7 (3.9%) in the performative quadrant ($\sigma \geq 0.50$, $\omega < 0.50$); none occupy the strategic quadrant ($\sigma \geq 0.70$, $\omega < 0.50$) or the “strategic obfuscator” quadrant ($\sigma \geq 0.60$, $\omega \geq 0.50$). The cluster visualization shows a dense concentration at $\sigma = 0.40$ – 0.50 , $\omega = 0.60$ – 0.75 , with a small tail of low-obfuscation outliers toward the performative boundary.

The absence of strategic obfuscators—firms with transparent privacy policies but high obfuscation—suggests that the privacy–finance compliance asymmetry implied by a purely strategic, rational-choice account [53] does not manifest in these data. The overwhelming pattern is joint low transparency: firms that underperform on privacy-policy structure also exhibit elevated obfuscation, supporting a *systems* view in which disclosure behavior is an integrated organizational characteristic rather than a domain-specific strategy.

and clarity (0.24) are critically low. The graphs lack the relational structure needed to connect disclosures into a coherent compliance narrative. This aligns with the broader observation that firms may satisfy formal requirements (naming data categories) while structurally disconnecting them from their regulatory context—purpose, legal basis, and retention [34].

4.9 Implications for Regulatory Practice and Forensic Application

The findings bear directly on the forensic and regulatory perspectives developed in Section 2. The 100% violation rate on purpose attribution (V12, X07, X08, R11) establishes an empirical baseline against which a specific firm’s Article 5(1)(b) compliance can be assessed, and the finding that no firm achieves strategic compliance furnishes a sector-wide norm for distinguishing inherent domain complexity from anomalous opacity. The severity-weighted analysis shows firms average 15.2 critical, 20.4 high, and 4.7 medium violations, with no significant cross-sector variation; critical violations—calibrated against enforcement actions exceeding €100M—constitute 37.8% of the total. For practitioners preparing expert testimony under Daubert-type standards, this distribution supports standardized risk assessment: a firm’s deviation from the sector mean on critical violations can be expressed as a z -score.

The obfuscation proxy ω , built from graph-derived metrics analogous to established financial-disclosure readability measures [15, 16, 49], supplies the cross-document measurement apparatus, and the σ – ω correlation confirms that the two dimensions capture related but distinct facets of disclosure behavior. Investigators can use the (σ, ω) coordinates to position a firm relative to the S&P 500 baseline, flag outliers, and track longitudinal changes in compliance posture.

4.10 Limitations

Five limitations bound the interpretation of these results.

- The obfuscation proxy ω is derived from graph-structural metrics rather than from actual SEC 10-K filings; although its components are grounded in the readability literature [15, 16, 49], it does not directly measure the linguistic characteristics of financial disclosures. Integrating Electronic Data Gathering, Analysis, and Retrieval (EDGAR)-sourced 10-K text to compute true obfuscation scores, and validating the proxy against established readability indices, is an important next step; until then, σ – ω findings should be read as associations among KG-derived proxies rather than as direct cross-regulatory measurements.
- Most importantly, the adapted-PoliGrapher construction pipeline shapes the detection results. Because each knowledge graph is produced by automated sentence-level

entity and relation extraction, the violation codes inherit the recall and precision of that pipeline: a disclosure stated in the source text but not extracted as a node or typed edge, owing to phrasing the extractor does not recognize, cross-sentence references it cannot resolve, or normalization that merges or omits a mention will register as a violation even though the obligation is nominally addressed. Several 100% violation rates (e.g. V08, V09, S09) may partly reflect the encoding scheme rather than genuine policy absence. For instance, data subject rights may be stated in text but not instantiated as discrete nodes or edges. The 0% rates for vagueness (X01–X03) and orphan-node codes (X09, X10) are the clearest symptom: graph construction abstracts away surface linguistic features, and prunes isolated nodes. Absolute violation rates should therefore be read as upper bounds conditioned on the representation, and triangulation with raw-text NLP analysis would strengthen the findings.

- Taxonomy thresholds ($\sigma = 0.50, 0.70$; $\omega = 0.50$) are calibrated against enforcement precedent but are not externally validated against regulatory outcomes; correlating composite scores with actual enforcement actions, consent orders, or breach frequency would establish predictive validity. Fourth, the analysis is cross-sectional and does not capture temporal dynamics such as post-breach policy updates or pre-enforcement drift.
- CCPA detection rates may understate compliance because “Do Not Sell” mechanisms are frequently implemented as separate web elements rather than integrated into the policy text from which graphs are built.

A ground-truth annotation study quantifying detector precision and recall against expert-labeled policies remains the most important direction for future validation.

5 Conclusion

This paper introduces a Privacy Policy Knowledge Graph (PPKG) framework that operationalizes multi-regulatory compliance as a graph-analytic problem, applying a taxonomy of 100 violation codes (95 GDPR-aligned codes and five CCPA extensions) spanning GDPR Articles 5–49 and CCPA §1798—to 179 S&P 500 companies across three GICS sectors. The framework contributes a severity-calibrated multi-regulatory taxonomy, a transparent graph-analytic detection methodology with a composite transparency score σ , and a compliance-tier classification, an obfuscation proxy ω that places each firm in a two-dimensional cross-document compliance space, and a large-scale empirical study of an economically significant corpus. The main finding is clear and consistent: none of the 179 firms achieve strategic compliance ($\sigma \geq 0.70$), 90.5% are classified as non-compliant, and the mean GDPR coverage is only 36.2%. Eleven violation codes, spanning five of the six research questions, trigger for every firm, and cross-sector differences in the composite score are not statistically significant ($H = 5.37$, $p = 0.068$), establishing the disclosure deficit as an economy-wide rather than sectoral phenomenon. Decomposing the score shows the deficit is structural rather than linguistic—transparency averages 0.99 while coverage, density, and clarity are critically low—meaning that S&P 500 policies are professionally worded yet fail to connect data collection to its purposes, legal bases, retention, and recipients. Finally, the significant negative correlation between transparency and obfuscation

($r = -0.303$, $p < 0.001$), together with the empty “strategic obfuscator” quadrant, supports a systems rather than strategic account of corporate disclosure: compliance behavior appears to be an integrated organizational characteristic that manifests consistently across regulatory domains. Collectively, these results furnish strong empirical support for a performative-compliance interpretation, in which firms adopt the formal structure of privacy disclosure without achieving its substantive transparency function.

References

- [1] European Parliament and Council of the European Union: Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the Protection of Natural Persons with Regard to the Processing of Personal Data and on the Free Movement of Such Data (General Data Protection Regulation). Official Journal of the European Union (2016). <https://eur-lex.europa.eu/eli/reg/2016/679/oj>
- [2] California State Legislature: California Consumer Privacy Act of 2018 (CCPA). California Civil Code. §§1798.100–1798.199 (2018). <https://oag.ca.gov/privacy/ccpa>
- [3] Irish Data Protection Commission: Decision Regarding Meta Platforms Ireland Limited (Schrems II Implementation). DPC Binding Decision. €1.2B fine for unlawful EU-US data transfers under GDPR Article 46(1) (2023). <https://www.dataprotection.ie/en/news-media/press-releases/data-protection-commission-announces-conclusion-inquiry-meta-ireland>
- [4] Luxembourg National Commission for Data Protection (CNPD): Decision Regarding Amazon Europe Core S.à r.l. CNPD Decision. €746M fine for GDPR violations in targeted advertising practices (2021). <https://cnpd.public.lu/en.html>
- [5] Irish Data Protection Commission: Decision Regarding LinkedIn Ireland Unlimited Company. DPC Decision. €310M fine for behavioral advertising consent violations under GDPR Articles 5, 6, and 13 (2024). <https://www.dataprotection.ie/en/news-media/press-releases/irish-dpc-fines-linkedin-ireland-eu310-million>
- [6] Reidenberg, J.R., Breaux, T., Cranor, L.F., French, B., Grannis, A., Graves, J.T., Liu, F., McDonald, A., Norton, T.B., Ramanath, R., Russell, N.C., Sadeh, N., Schaub, F.: Disagreeable privacy policies: Mismatches between meaning and users’ understanding. *Berkeley Technology Law Journal* **30**(1), 39–88 (2015) <https://doi.org/10.15779/Z384K33>
- [7] Obar, J.A., Oeldorf-Hirsch, A.: The biggest lie on the internet: Ignoring the privacy policies and terms of service policies of social networking services. *Information, Communication & Society* **23**(1), 128–147 (2020) <https://doi.org/10.1080/1369118X.2018.1486870>

- [8] Wilson, S., Schaub, F., Dara, A.A., Liu, F., Cherivirala, S., Leon, P.G., Andersen, M.S., Zimmeck, S., Sathyendra, K.M., Russell, N.C., Norton, T.B., Hovy, E., Reidenberg, J., Sadeh, N.: The creation and analysis of a website privacy policy corpus. In: Proceedings of the 54th Annual Meeting of the Association for Computational Linguistics (Volume 1: Long Papers), pp. 1330–1340 (2016). <https://doi.org/10.18653/v1/P16-1126>
- [9] Zimmeck, S., Story, P., Smullen, D., Ravichander, A., Wang, Z., Reidenberg, J.R., Russell, N.C., Sadeh, N.: MAPS: Scaling privacy compliance analysis to a million apps. In: Proceedings on Privacy Enhancing Technologies, vol. 2019, pp. 66–86 (2019). <https://doi.org/10.2478/popets-2019-0037>
- [10] Harkous, H., Fawaz, K., Lebet, R., Schaub, F., Shin, K.G., Aberer, K.: Polis: Automated analysis and presentation of privacy policies using deep learning. In: 27th USENIX Security Symposium (USENIX Security 18), pp. 531–548. USENIX Association, ??? (2018). arXiv: 1802.02561
- [11] Cui, H., Trimananda, R., Markopoulou, A., Jordan, S.: PoliGraph: Automated privacy policy analysis using knowledge graphs. In: Proceedings of the 32nd USENIX Security Symposium (USENIX Security 23), pp. 1037–1054. USENIX Association, Anaheim, CA (2023)
- [12] Andow, B., Mahmud, S.Y., Wang, W., Whitaker, J., Enck, W., Reaves, B., Singh, K., Xie, T.: PolicyLint: Investigating internal privacy policy contradictions on Google Play. In: Proceedings of the 28th USENIX Security Symposium (USENIX Security 19), pp. 585–602. USENIX Association, Santa Clara, CA (2019)
- [13] Barrett, S., Ramasamy, V., Dorai, G., Boswell, B.: Navigating privacy policies with NLP and graph mining: Advancements in user-centric legal document analysis. In: IEEE SoutheastCon 2025, pp. 1013–1022. IEEE, ??? (2025). <https://doi.org/10.1109/SoutheastCon56624.2025.10971616>
- [14] Ramasamy, V., Barrett, S., Dorai, G., Zumbach, J.: Unveiling privacy policy complexity: An exploratory study using graph mining, machine learning, and natural language processing. In: IEEE SoutheastCon 2025. IEEE, ??? (2025). arXiv: 2507.02968
- [15] Li, F.: Annual report readability, current earnings, and earnings persistence. *Journal of Accounting and Economics* **45**(2–3), 221–247 (2008) <https://doi.org/10.1016/j.jacceco.2008.02.003>
- [16] Loughran, T., McDonald, B.: Measuring readability in financial disclosures. *The Journal of Finance* **69**(4), 1643–1671 (2014) <https://doi.org/10.1111/jof.12162>
- [17] Pollach, I.: What’s wrong with online privacy policies? *Communications of the ACM* **50**(9), 103–108 (2007) <https://doi.org/10.1145/1284621.1284627>

- [18] Costante, E., Sun, Y., Petković, M., Hartog, J.: A machine learning solution to assess privacy policy completeness: (short paper). In: Proceedings of the 2012 ACM Workshop on Privacy in the Electronic Society, pp. 91–96 (2012). <https://doi.org/10.1145/2381966.2381979>
- [19] Libert, T.: An automated approach to auditing disclosure of third-party data collection in website privacy policies. In: Proceedings of the 2018 World Wide Web Conference (WWW '18), pp. 207–216 (2018). arXiv: 1805.01187
- [20] Lebanoff, L., Liu, F.: Automatic detection of vague words and sentences in privacy policies. In: Proceedings of the 2018 Conference on Empirical Methods in Natural Language Processing, pp. 3508–3517 (2018). <https://doi.org/10.18653/v1/D18-1387>
- [21] Reimers, N., Gurevych, I.: Sentence-BERT: Sentence embeddings using Siamese BERT-networks. In: Proceedings of the 2019 Conference on Empirical Methods in Natural Language Processing and the 9th International Joint Conference on Natural Language Processing (EMNLP-IJCNLP), pp. 3982–3992. Association for Computational Linguistics, Hong Kong, China (2019). <https://doi.org/10.18653/v1/D19-1410>
- [22] Elluri, L., Nagar, A., Joshi, K.P.: An integrated knowledge graph to automate GDPR and PCI DSS compliance. In: Proceedings of the 2018 IEEE International Conference on Big Data (Big Data), pp. 1266–1271. IEEE, ??? (2018). <https://doi.org/10.1109/BigData.2018.8622236>
- [23] Tauqeer, A., Kurteva, A., Chhetri, T.R., Ahmeti, A., Fensel, A.: Automated GDPR contract compliance verification using knowledge graphs. *Information* **13**(10), 447 (2022) <https://doi.org/10.3390/info13100447>
- [24] Boi, B., Esposito, C.: Using knowledge graphs to ensure privacy policies in decentralized data collection systems. In: Proceedings of the 2023 International Conference on Research in Adaptive and Convergent Systems (RACS '23), pp. 1–6. ACM, ??? (2023). <https://doi.org/10.1145/3599957.3606213>
- [25] Federal Trade Commission: FTC Says Ring Employees Illegally Surveilled Customers. \$5.8 million settlement for privacy violations (2023)
- [26] Schaub, F., Balebako, R., Durity, A.L., Cranor, L.F.: A design space for effective privacy notices. In: Eleventh Symposium On Usable Privacy and Security (SOUPS 2015), pp. 1–17. USENIX Association, ??? (2015)
- [27] Liu, B., Andersen, M.S., Schaub, F., Almuhiemedi, H., Zhang, S.A., Sadeh, N., Agarwal, Y., Acquisti, A.: Follow my recommendations: A personalized privacy assistant for mobile app permissions. In: Twelfth Symposium on Usable Privacy and Security (SOUPS 2016), pp. 27–41. USENIX Association, ??? (2016)

- [28] Health Insurance Portability and Accountability Act. Pub. L. No. 104-191, 110 Stat. 1936 (1996)
- [29] State of Illinois: Illinois Biometric Information Privacy Act. 740 ILCS 14/ (2008)
- [30] Solove, D.J.: Introduction: Privacy self-management and the consent dilemma. *Harvard Law Review* **126**(7), 1880–1903 (2013)
- [31] Federal Trade Commission: FTC Imposes \$5 Billion Penalty and Sweeping New Privacy Restrictions on Facebook. Press Release (2019). <https://www.ftc.gov/news-events/news/press-releases/2019/07/ftc-imposes-5-billion-penalty-sweeping-new-privacy-restrictions-facebook>
- [32] Federal Trade Commission: FTC Charges Twitter with Deceptively Using Account Security Data for Targeted Advertising. \$150 million settlement (2022)
- [33] Attorneys General Multistate: Google to Pay \$391.5 Million in Historic Privacy Settlement with 40 States. Location tracking deception settlement (2022)
- [34] Ermakova, T., Fabian, B., Baumann, A., Izmailov, M.: Understanding website privacy policies—a longitudinal analysis using natural language processing. *Information* **14**(11), 622 (2023) <https://doi.org/10.3390/info14110622>
- [35] Cranor, L.F.: Necessary but not sufficient: Standardized mechanisms for privacy notice and choice. *Journal on Telecommunications and High Technology Law* **10**, 273–308 (2012)
- [36] Cate, F.H., Mayer-Schönberger, V.: Notice and consent in a world of big data. *International Data Privacy Law* **3**(2), 67–73 (2013) <https://doi.org/10.1093/idpl/ipt005>
- [37] Federal Trade Commission: FTC Proposes Blanket Prohibition Preventing Facebook from Monetizing Youth Data. Press Release (2023). <https://www.ftc.gov/news-events/news/press-releases/2023/05/ftc-proposes-blanket-prohibition-preventing-facebook-monetizing-youth-data>
- [38] Federal Trade Commission: Amazon to Pay \$25 Million Over Alexa Privacy Violations. Case No. 2:23-cv-00853, W.D. Washington (2023)
- [39] In re Apple Inc. Siri Privacy Litigation. Case No. 5:19-cv-04577, N.D. California. Siri recording without consent class action (2019)
- [40] Amazon Faces Biometric Privacy Class Action Over Alexa Recordings. Case No. 2:21-cv-00782, W.D. Washington (2021)
- [41] Federal Trade Commission: Children’s Online Privacy Protection Act. 15 U.S.C. §§ 6501–6506 (1998)

- [42] Federal Trade Commission: Google and YouTube Will Pay Record \$170 Million for Alleged Violations of Children’s Privacy Law. Press Release (2019)
- [43] Federal Trade Commission: Microsoft to Pay \$20 Million for Illegally Collecting Children’s Data. Xbox account creation violations (2023)
- [44] Federal Trade Commission: Video Social Networking App Musical.ly Agrees to Settle FTC Allegations. \$5.7 million COPPA violation settlement (2019)
- [45] Thornton, I. et al. v. Facebook: Meta to Pay \$650 Million in Biometric Privacy Lawsuit Settlement. Case No. 3:15-cv-03747, N.D. Illinois (2021)
- [46] TikTok Faces Illinois Biometric Privacy Lawsuit. Multiple consolidated cases under BIPA (2023)
- [47] Brown v. Google LLC. Case No. 5:20-cv-03664, N.D. California. Incognito mode tracking class action (2024)
- [48] Apple Faces Class Action Over App Tracking Despite Privacy Claims. Rhodes v. Apple Inc., Case No. 3:21-cv-06848, N.D. California (2021)
- [49] Bloomfield, R.J.: The incomplete revelation hypothesis and financial reporting. *Accounting Horizons* **16**(3), 233–243 (2002) <https://doi.org/10.2308/acch.2002.16.3.233>
- [50] Hagberg, A.A., Schult, D.A., Swart, P.J.: Exploring network structure, dynamics, and function using NetworkX. In: Proceedings of the 7th Python in Science Conference (SciPy 2008), pp. 11–15 (2008). <https://doi.org/10.25080/tcwg9851>
- [51] Rahat, T.A., Long, M., Tian, Y.: Is your policy compliant? a deep learning-based empirical study of privacy policies’ compliance with gdpr. In: Proceedings of the 21st Workshop on Privacy in the Electronic Society. WPES’22, pp. 89–102. Association for Computing Machinery, New York, NY, USA (2022). <https://doi.org/10.1145/3559613.3563195>
- [52] California Office of the Attorney General: In the Matter of Sephora USA, Inc. Settlement Agreement. \$1.2M penalty for CCPA opt-out of sale violations under §1798.120 (2022). <https://oag.ca.gov/news/press-releases/attorney-general-bonta-announces-settlement-sephora-part-ongoing-enforcement>
- [53] Becker, G.S.: Crime and punishment: An economic approach. *Journal of Political Economy* **76**(2), 169–217 (1968) <https://doi.org/10.1086/259394>